

UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ
Ingeniería en Tecnologías de la Información

PARCIAL I: FUNDAMENTOS DE CIBERSEGURIDAD

ACTIVIDAD 04

Una página demasiado convincente

Informe de práctica de laboratorio – Simulación de ingeniería social con Social-Engineer Toolkit (SET)

Alumno:

Luis Felipe Jaramillo Barajas

Número de control / matrícula:

183559

Docente:

Mtro. Servando López Contreras

Fecha:

31 de agosto de 2026

Tabla de índice

Tabla de índice	2
1. Objetivo de la actividad.....	3
Objetivo general	3
Objetivos específicos.....	3
2. Descripción del escenario	3
3. Configuración del laboratorio.....	3
Restricciones aplicadas durante la práctica (cumplimiento obligatorio)	3
Topología de red	4
Herramienta utilizada	4
4. Evidencias y descripción del funcionamiento	4
4.1 Configuración de red.....	4
4.2 Configuración de SET y Credential Harvester.....	7
4.3 Página web ficticia (WatchLF).....	7
4.4 Captura de credenciales de prueba.....	9
4.5 Reporte generado por SET	9
5. Explicación del flujo de captura de información	10
Diagrama del flujo de captura	10
6. Identificación de indicadores de phishing.....	11
7. Controles de seguridad propuestos	11
8. Conclusión	12
9. Referencias.....	12

1. Objetivo de la actividad

Objetivo general

Implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante Social-Engineer Toolkit (SET), utilizando una página web ficticia (WatchLF) para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

Objetivos específicos

- Configurar un escenario básico de ingeniería social utilizando Social-Engineer Toolkit (SET).
- Implementar una página web ficticia mediante el módulo Credential Harvester.
- Analizar el proceso mediante el cual la información introducida en un formulario web es transmitida y registrada por un servidor.
- Identificar indicadores técnicos y visuales que permitan reconocer una página potencialmente fraudulenta.
- Proponer controles de seguridad orientados a prevenir o reducir el impacto de ataques de phishing.

2. Descripción del escenario

El área de seguridad informática de una organización ficticia recibió reportes de empleados que aseguran haber recibido un mensaje relacionado con una supuesta actualización de sus credenciales.

El mensaje dirige a un portal aparentemente institucional, con logotipo, campos de usuario y contraseña, y un mensaje indicando que la sesión ha expirado. A primera vista nada parece fuera de lo común; sin embargo, el portal no pertenece a la organización real, sino a una plataforma de streaming ficticia diseñada para esta práctica, denominada WatchLF.

Con fines exclusivamente académicos, se reprodujo este escenario en un laboratorio aislado, generando una página propia (no una copia de un servicio real) y utilizando el módulo Credential Harvester de SET para observar cómo se comporta técnicamente este tipo de ataque.

3. Configuración del laboratorio

Restricciones aplicadas durante la práctica (cumplimiento obligatorio)

Antes de iniciar la configuración técnica, se definió un conjunto de restricciones con el fin de mantener la práctica dentro de un marco estrictamente académico y controlado:

- No se utilizaron páginas pertenecientes a servicios reales.
- No se clonaron portales de instituciones o empresas; en su lugar, se usó la opción Custom Import con una página propia.
- No se emplearon credenciales personales, únicamente datos de prueba inventados.
- No se solicitaron datos a personas ajenas al laboratorio.
- El servidor nunca fue publicado hacia Internet; se mantuvo en una red interna de tipo host-only.
- No se utilizaron dominios externos ni técnicas de suplantación DNS.

- No se instalaron payloads ni se ejecutó código malicioso de ningún tipo.

Topología de red

El laboratorio se conformó por dos equipos: una laptop personal (host, actuando como equipo 'víctima') y una máquina virtual con Kali Linux (actuando como servidor del ataque simulado), ambos conectados mediante un adaptador Host-Only de VirtualBox. Este tipo de adaptador crea un segmento de red aislado, visible únicamente entre el host y la VM, sin ruta hacia Internet ni hacia la red física, cumpliendo así la restricción de no exponer el servidor.

- IP asignada a Kali (servidor del ataque): 192.168.56.101
- IP asignada a la laptop (equipo víctima): dentro del mismo segmento 192.168.56.0/24
- Verificación de aislamiento: ping desde Kali hacia una IP externa (8.8.8.8) sin respuesta, confirmando que el segmento no tiene salida a Internet.

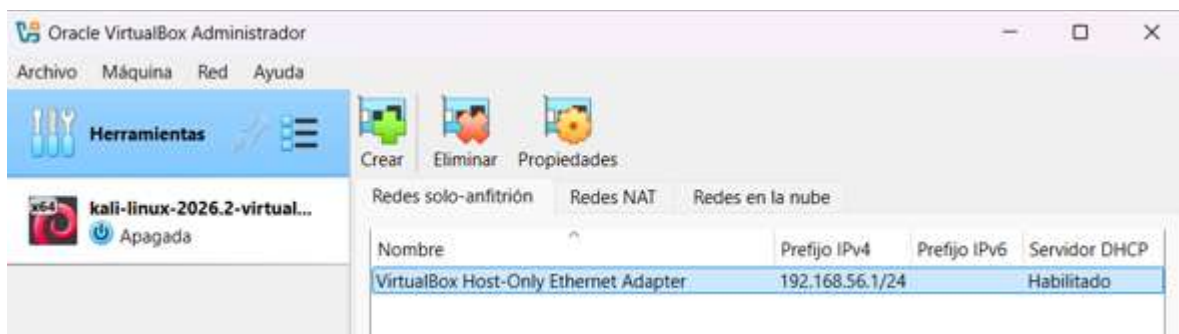
Herramienta utilizada

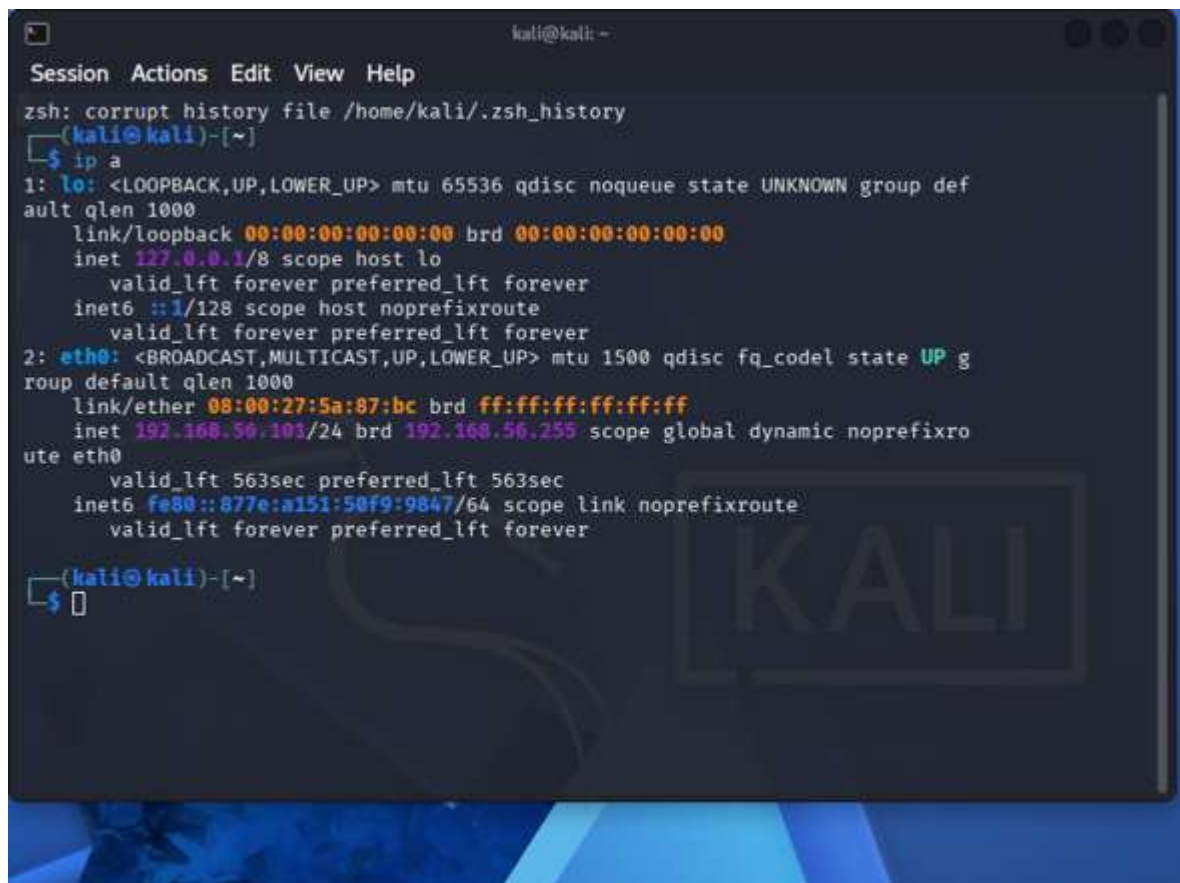
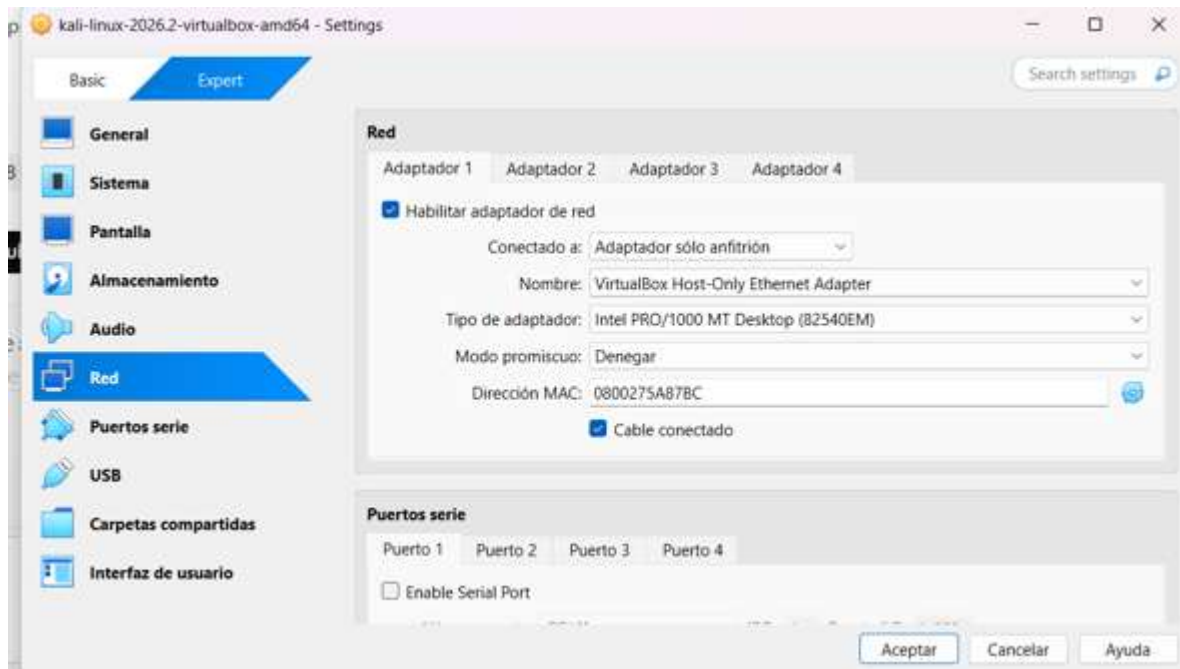
Social-Engineer Toolkit (SET), específicamente el módulo Website Attack Vectors → Credential Harvester Attack Method, con la opción Custom Import (importación de una página propia en lugar de clonar un sitio real).

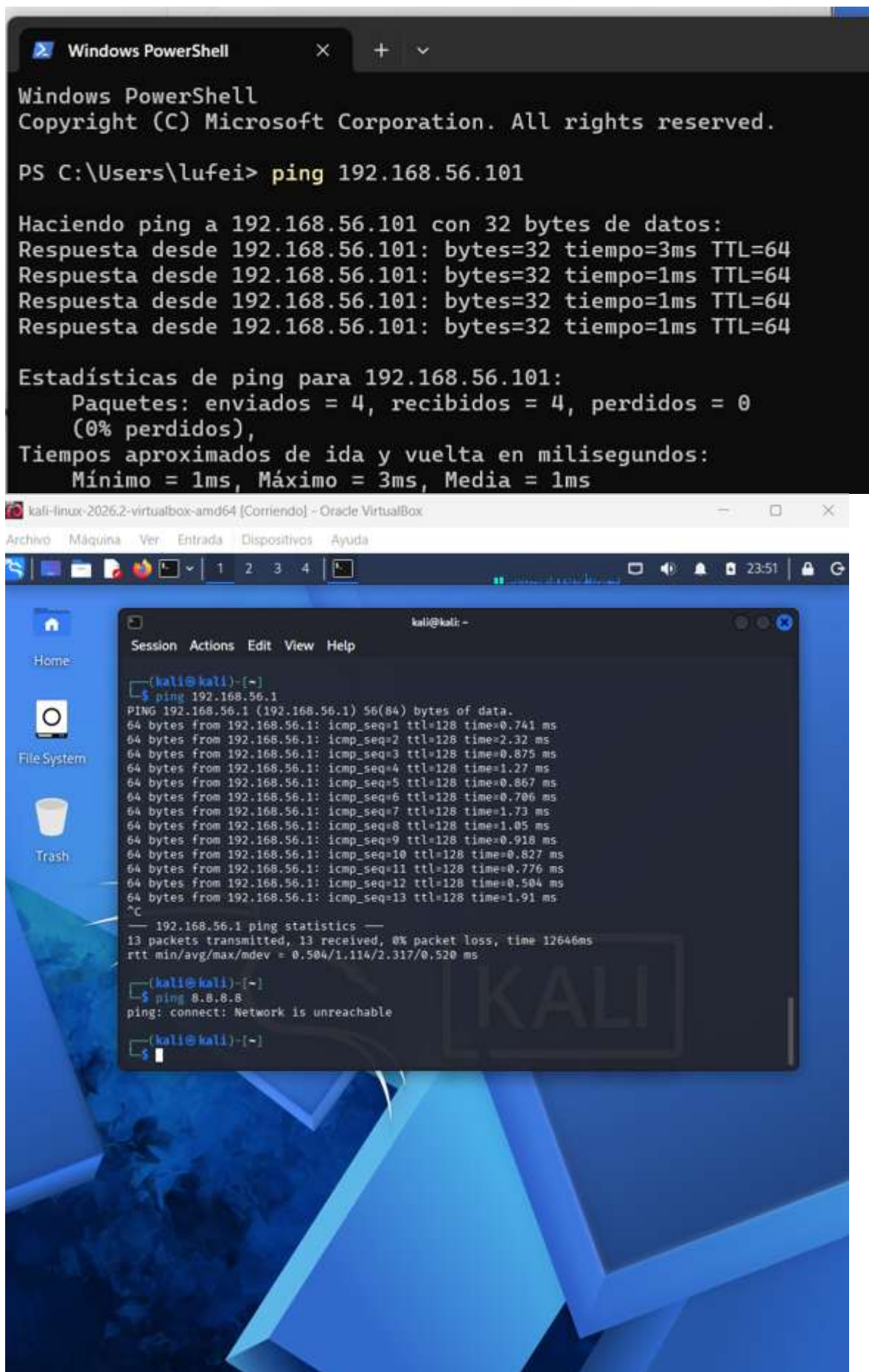
4. Evidencias y descripción del funcionamiento

A continuación se documenta paso a paso el proceso realizado, con su respectiva evidencia fotográfica.

4.1 Configuración de red







4.2 Configuración de SET y Credential Harvester

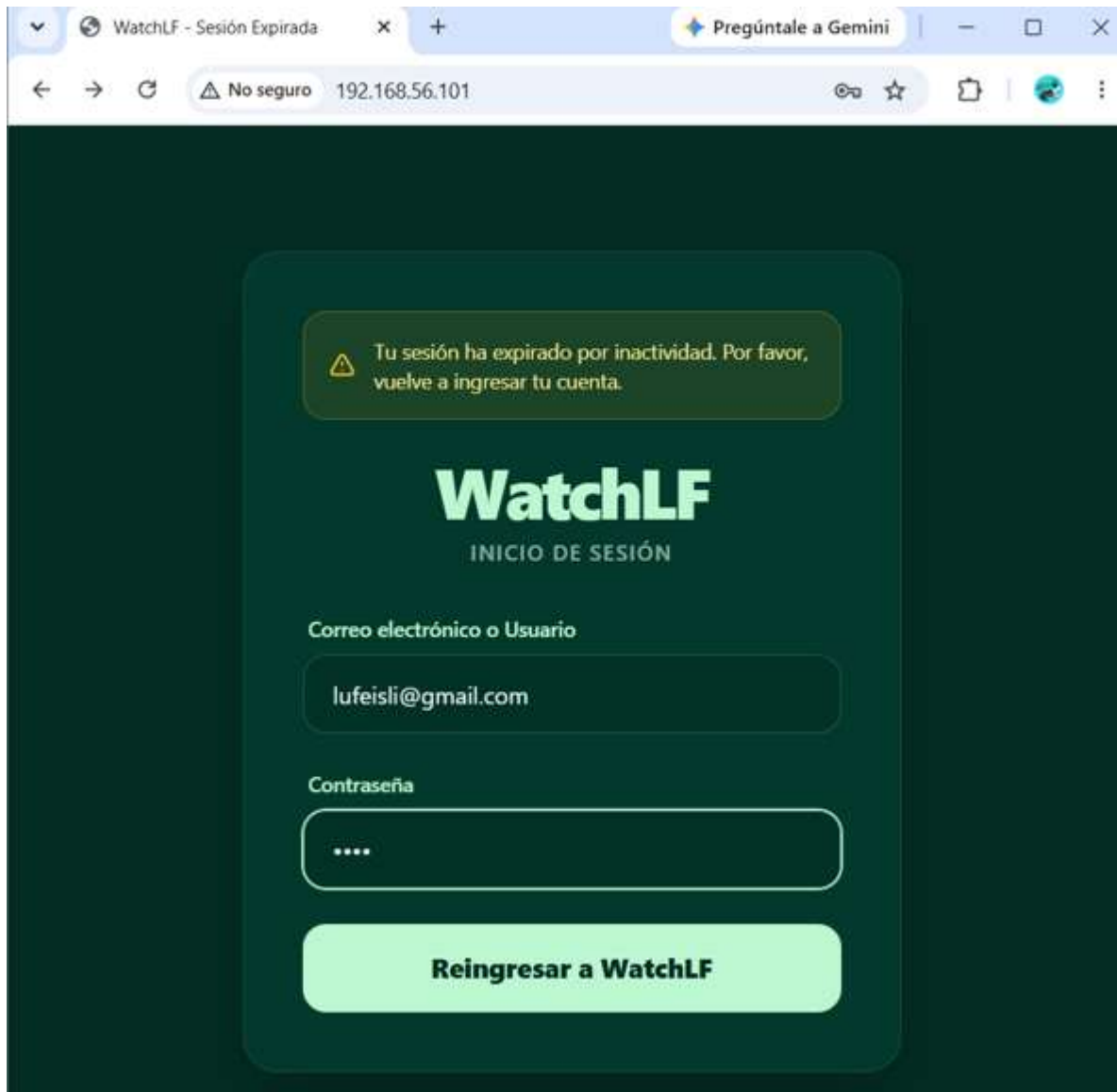
menú de SET

(Social-Engineering Attacks → Website Attack Vectors → Credential Harvester Attack Method → Custom Import)

```
kali@kali: ~  
Session Actions Edit View Help  
address. A browser doesn't know how to communicate with a private IP  
address, so if you don't specify an external IP address if you are using  
this from an external perspective, it will not work. This isn't a SET issue  
this is how networking works.  
  
Enter the IP address for POST back in Harvester/Tabnabbing: 192.168.56.101  
[!] Example: /home/website/ (make sure you end with /)  
[!] Also note that there MUST be an index.html in the folder you point to.  
set:webattack> Path to the website to be cloned: /home/kali/watchlf/  
[*] Index.html found. Do you want to copy the entire folder or just index.html?  
  
1. Copy just the index.html  
2. Copy the entire folder  
  
Enter choice [1/2]: 1  
[-] Example: http://www.blah.com  
set:webattack> URL of the website you imported: http://www.watchlf.com  
  
The best way to use this attack is if username and password form fields are available. Rega  
ardless, this captures all POSTs on a website.  
[*] The Social-Engineer Toolkit Credential Harvester Attack  
[*] Credential Harvester is running on port 80  
[*] Information will be displayed to you as it arrives below:
```

4.3 Página web ficticia (WatchLF)

```
File Edit Search View Document Help  
1 <DOCTYPE html>  
2 <html lang="es">  
3 <head>  
4 <meta charset="UTF-8">  
5 <meta name="viewport" content="width=device-width, initial-scale=1.0">  
6 <title>WatchLF - Sesión expirada</title>  
7 <script src="https://cdn.tailwindcss.com" defer></script>  
8 </head>  
9 <body class="min-h-screen bg-emerald-900 flex items-center justify-center p-4 font-sans selection:bg-  
green-200 selection:text-emerald-400">  
10 <div class="max-w-md w-full bg-emerald-900/40 backdrop-blur-lg rounded-2xl shadow-2xl p-6 sm:p-10  
border border-green-200/10">  
11 <div class="mb-4 p-4 rounded-2xl bg-white/10 border border-white/10 text-white/200 flex  
items-center justify-center">  
12 <img alt="WatchLF logo" data-bbox="100 620 150 650" style="height: 40px; width: 40px;"/>  
13 <div class="flex flex-col items-center justify-center text-center">  
14 <div class="font-size-24 font-weight-bold text-emerald-400">WatchLF</div>  
15 <div class="font-size-16 text-emerald-400">Sesión expirada</div>  
16 </div>  
17 <div class="text-center mt-4">  
18 <div class="text-white/20 font-size-14">Tu sesión ha expirado por inactividad. Por favor, vuelve a ingresar tu cuenta.</div>  
19 </div>  
20 <div class="text-center mt-4">  
21 <div class="text-emerald-400 font-weight-bold text-size-16">¡Vuelve a entrar!</div>  
22 </div>  
23 </div>  
24 <div class="text-center mt-4">  
25 <div class="font-size-14 text-white/20">¿No recuerdas tu contraseña?</div>  
26 <div class="font-size-14 text-white/20"><a href="#">¿No tienes cuenta?</a></div>  
27 </div>
```



4.4 Captura de credenciales de prueba

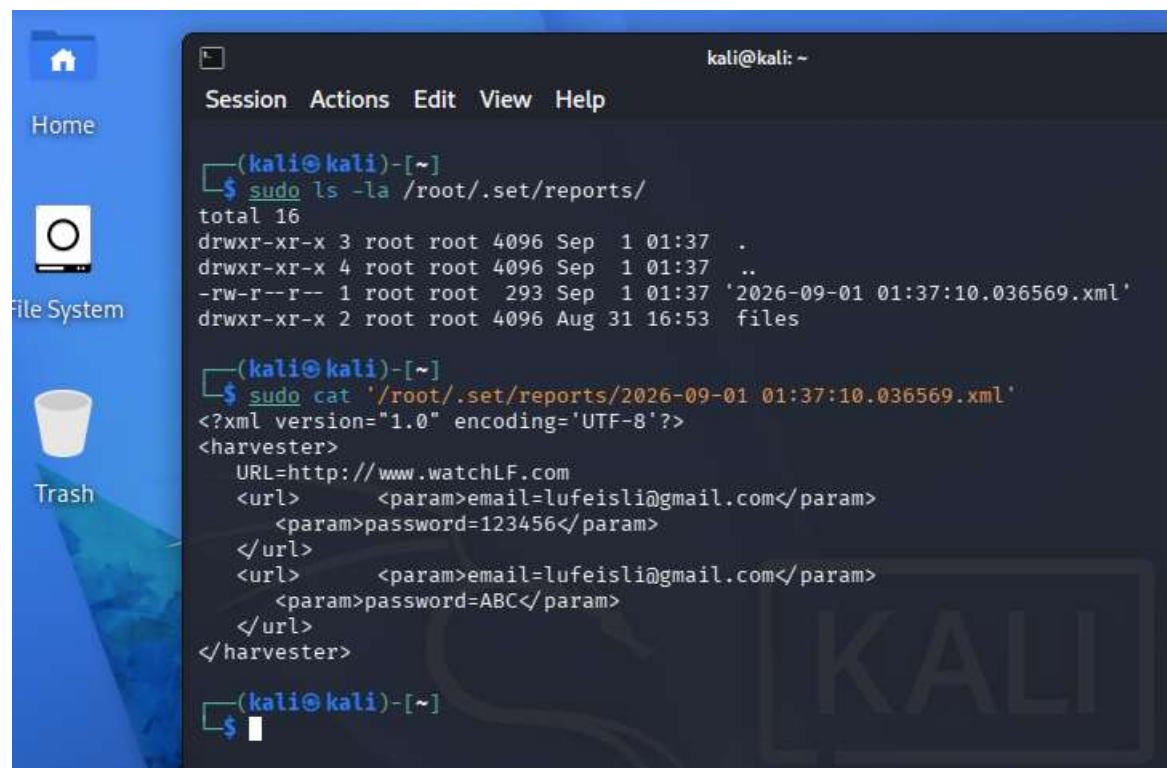
```
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.56.1 - - [01/Sep/2026 00:57:57] "GET / HTTP/1.1" 200 -
192.168.56.1 - - [01/Sep/2026 00:57:58] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: email=lufeisli@gmail.com
POSSIBLE PASSWORD FIELD FOUND: password=123456
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

192.168.56.1 - - [01/Sep/2026 00:58:42] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: email=lufeisli@gmail.com
POSSIBLE PASSWORD FIELD FOUND: password=ABC
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

192.168.56.1 - - [01/Sep/2026 01:04:32] "GET / HTTP/1.1" 200 -
^C
Press <return> to continue
192.168.56.1 - - [01/Sep/2026 01:05:14] "GET / HTTP/1.1" 200 -
^C
```

4.5 Reporte generado por SET

Al finalizar la captura y presionar Ctrl+C, SET genera automáticamente un reporte en /root/.set/reports/, en formato .html y .xml, con el detalle de la IP de origen, fecha, hora y los campos capturados.



```
kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ sudo ls -la /root/.set/reports/
total 16
drwxr-xr-x 3 root root 4096 Sep  1 01:37 .
drwxr-xr-x 4 root root 4096 Sep  1 01:37 ..
-rw-r--r-- 1 root root 293 Sep  1 01:37 '2026-09-01 01:37:10.036569.xml'
drwxr-xr-x 2 root root 4096 Aug 31 16:53 files

(kali@kali)-[~]
$ sudo cat '/root/.set/reports/2026-09-01 01:37:10.036569.xml'
<?xml version="1.0" encoding='UTF-8'?>
<harvester>
  URL=http://www.watchLF.com
  <url>      <param>email=lufeisli@gmail.com</param>
            <param>password=123456</param>
  </url>
  <url>      <param>email=lufeisli@gmail.com</param>
            <param>password=ABC</param>
  </url>
</harvester>

(kali@kali)-[~]
$
```

5. Explicación del flujo de captura de información

El proceso completo de captura sigue la siguiente secuencia técnica:

- 1) El usuario recibe un enlace y accede a la página ficticia de WatchLF alojada en el servidor de Kali (<http://192.168.56.101>).
- 2) El navegador renderiza el formulario HTML, que contiene los campos 'email' y 'password' dentro de una etiqueta <form> con method="POST" y action="/".
- 3) Al presionar 'Reingresar a WatchLF', el navegador construye una petición HTTP POST hacia la raíz del servidor, incluyendo los valores introducidos como pares campo=valor en el cuerpo de la solicitud.
- 4) El servidor web temporal levantado por SET (módulo Credential Harvester) recibe la petición POST, y en lugar de procesarla como un login real, extrae e imprime en pantalla los parámetros recibidos.
- 5) SET identifica automáticamente qué campos corresponden a usuario y contraseña (etiquetándolos como 'POSSIBLE USERNAME FIELD FOUND' y 'POSSIBLE PASSWORD FIELD FOUND') y los registra en el archivo de reporte.
- 6) El usuario, sin saberlo, ha entregado sus credenciales al atacante en lugar de autenticarse en un sistema real; en un escenario real, el atacante podría además redirigir al usuario a la página legítima para no levantar sospechas.

Diagrama del flujo de captura

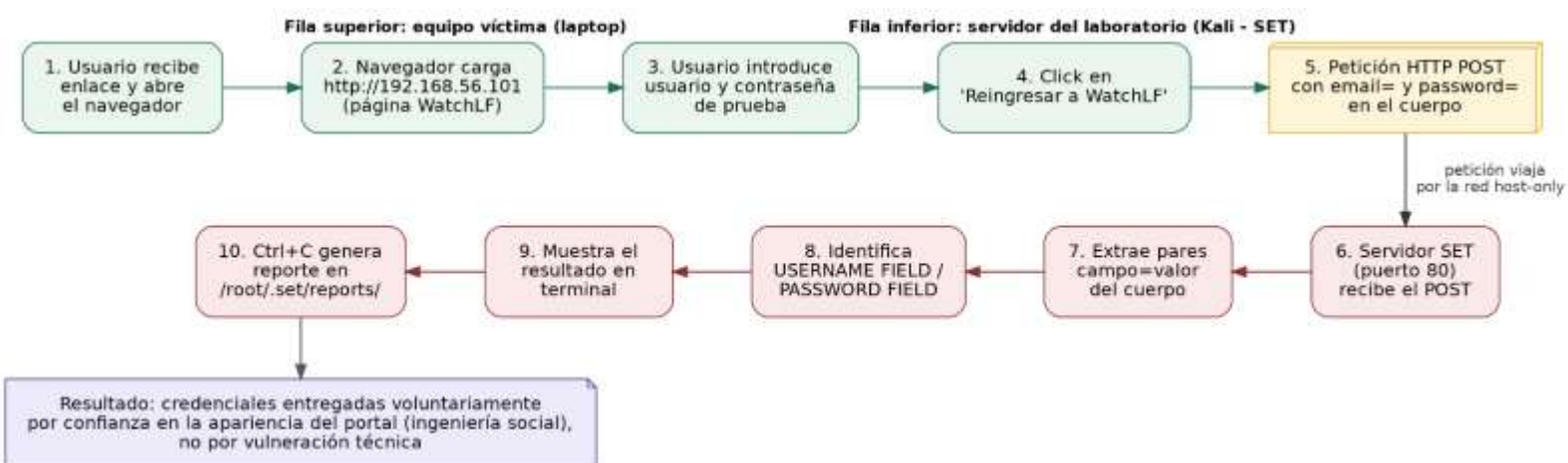


Figura 1. Flujo técnico de la captura de credenciales mediante Credential Harvester (SET).

Es importante distinguir este proceso de una vulneración de contraseña: en ningún momento se rompió cifrado ni se atacó un sistema de autenticación real; la contraseña fue entregada voluntariamente por la víctima al confiar en la apariencia legítima del portal, lo cual es la esencia de un ataque de ingeniería social.

6. Identificación de indicadores de phishing

A partir del análisis de la página implementada, se identificaron los siguientes indicadores que permitirían a un usuario atento reconocer que se trata de un portal fraudulento:

#	Indicador / Control	Descripción y justificación
1	URL / dominio no oficial	El portal no pertenece al dominio real del servicio (p. ej. no es watchlf.com sino una IP local o un dominio distinto), lo cual es verificable revisando la barra de direcciones antes de introducir credenciales.
2	Ausencia de certificado HTTPS válido	El sitio de laboratorio corre sobre HTTP plano en el puerto 80, sin candado de seguridad ni certificado emitido por una autoridad reconocida, señal típica de un sitio no legítimo.
3	Mensaje de urgencia o expiración de sesión	El texto 'Tu sesión ha expirado por inactividad' busca generar una reacción rápida en el usuario para que ingrese sus credenciales sin analizar la página.
4	Lógica de autenticación expuesta en el cliente	En la versión inicial de la página, las credenciales de validación estaban visibles en el código fuente del navegador, evidenciando que no existe un backend real de autenticación.
5	Formulario que envía datos a un destino no verificado	El formulario reenvía la información mediante POST a una dirección IP interna en lugar de a un servidor institucional conocido, algo que puede confirmarse inspeccionando el atributo action del formulario.

7. Controles de seguridad propuestos

Como medida preventiva frente a ataques de este tipo, se proponen los siguientes controles de seguridad:

#	Indicador / Control	Descripción y justificación
1	Verificación del certificado TLS/SSL	Antes de introducir cualquier credencial, el usuario debe confirmar que la conexión use HTTPS con un certificado válido emitido para el dominio real del servicio.
2	Autenticación multifactor (MFA)	Aun si las credenciales son capturadas, un segundo factor (token, aplicación autenticadora o SMS) evita que el atacante pueda iniciar sesión con solo usuario y contraseña.
3	Capacitación continua en concientización de phishing	Programas periódicos de concientización ayudan a que el personal reconozca mensajes de urgencia, dominios sospechosos y solicitudes inusuales de credenciales.
4	Filtrado de correo y bloqueo de dominios maliciosos	Soluciones de seguridad de correo (anti-phishing, SPF/DKIM/DMARC) y listas de bloqueo de dominios reducen la probabilidad de que el enlace fraudulento llegue a la bandeja de entrada.

#	Indicador / Control	Descripción y justificación
5	Monitoreo y respuesta ante incidentes	Contar con un proceso definido para que los empleados reporten mensajes sospechosos, y un equipo de seguridad que analice y bloquee rápidamente el recurso malicioso identificado.

8. Conclusión

La realización de esta práctica permitió comprender, de forma directa y controlada, por qué la ingeniería social continúa siendo una de las técnicas de ataque más efectivas dentro de la ciberseguridad, incluso cuando las organizaciones cuentan con controles técnicos robustos. Configurar y ejecutar el módulo Credential Harvester de Social-Engineer Toolkit evidenció que el proceso de captura no depende de vulnerar ningún sistema criptográfico ni de explotar una falla de software, sino de aprovechar la confianza del usuario en la apariencia visual de un sitio.

Una página con un diseño cuidado, un mensaje de urgencia bien redactado y un formulario aparentemente legítimo son suficientes para que la información sea entregada de forma voluntaria.

Desde el punto de vista técnico, quedó claro que el flujo completo depende de un elemento sencillo: una petición HTTP POST hacia un servidor que el atacante controla. Esto reforzó la importancia de revisar aspectos que suelen pasarse por alto, como el dominio real de un sitio, la presencia de un certificado válido y el comportamiento del formulario antes de introducir cualquier credencial.

Finalmente, esta actividad deja como principal aprendizaje que la tecnología por sí sola no es suficiente para contener el phishing: la concientización constante del usuario final, combinada con controles como la autenticación multifactor y el filtrado de correo, sigue siendo la línea de defensa más determinante frente a este tipo de amenazas.

9. Referencias

Cybersecurity and Infrastructure Security Agency. (s.f.). *Recognize and report phishing*. CISA. Recuperado el 1 de septiembre de 2026, de <https://www.cisa.gov/secure-our-world/recognize-and-report-phishing>

National Institute of Standards and Technology. (2025). *Digital identity guidelines: Authentication and authenticator management (NIST SP 800-63B-4)*. U.S. Department of Commerce. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63B-4.pdf>

Oracle Corporation. (s.f.). *Host-only networking*. En *Oracle VM VirtualBox user manual*. Recuperado el 1 de septiembre de 2026, de <https://www.virtualbox.org/manual/ch06.html>

OWASP Foundation. (s.f.). *Credential stuffing*. Recuperado el 1 de septiembre de 2026, de https://owasp.org/www-community/attacks/Credential_stuffing

TrustedSec. (s.f.). *Social-Engineer Toolkit (SET) [Software]*. GitHub. Recuperado el 1 de septiembre de 2026, de <https://github.com/trustedsec/social-engineer-toolkit>